

CAM INITIATIVE

TARGETED SUBMISSION ON PROPOSED AMENDMENTS TO THE SECURITY OF CRITICAL INFRASTRUCTURE ACT 2018

Submitted by

Dr Michelle Vivian O'Rourke

Aeon Governance Lab | CAM Initiative

29 July 2026 | Independent public-interest submission

www.cam-initiative.org



CAM INITIATIVE

Executive summary

CAM supports the Department of Home Affairs' proposed clarification of cyber security incidents involving automated systems, software agents and AI-enabled tools. The most useful refinement is to separate incident classification from later questions of attribution, originating purpose and culpability. A reportable event may be evident before a natural-person actor, complete causal chain or malicious intention can be established. [1]

This targeted submission responds only to consultation questions where CAM has a specific operational contribution: material dependency information; automated-system incidents; preliminary good-faith reporting; CIRMP assurance; relevant operators; supplier assurance; and specified risk information. It does not propose a general AI incident regime or seek to restate matters already adequately addressed in the consultation paper.

Seven targeted recommendations

1. Use three proportionate information layers: a public sector-and-dependency overview, the non-public statutory Register, and a separately compartmentalised operational-security layer for exploitable details.
2. Classify an incident on objective security and operational facts, while assessing causal attribution, originating purpose, authority and culpability separately.
3. Clarify that general authority to operate an automated system does not authorise every resulting action or effect, including effects produced through compromise, prompt injection, manipulated tool output, dependency compromise or containment failure.
4. Examine a bounded protected preliminary reporting route for persons who identify or may have unintentionally contributed to an incident but are not the impacted entity or acting on its behalf.
5. Place incident-stewardship duties on systemically significant providers where they hold superior telemetry, practical control or remediation capability, and use common event identifiers for shared provider incidents.
6. Test CIRMP controls through design, implementation, operating effectiveness, dependency and independence assurance, and verified remediation closure - not document review alone.
7. Preserve evidence quality and honest uncertainty by distinguishing raw telemetry, derived analysis, record integrity, capture accuracy and confidence-rated actor attribution.

Contents

1. About this submission
2. Measure 2 - Material digital dependency information
3. Measure 5 - Automated systems, software agents and AI
4. Preliminary good-faith reporting gap
5. Measure 15 - CIRMP governance and assurance
6. Measure 17 - Relevant operators and foreign-control continuity
7. Measure 19 - Supply-chain cyber security assurance
8. Measure 20 - Specified risk information
9. Conclusion
10. References

1. About this submission

The CAM Initiative is an independent Australian governance-engineering initiative developing public governance architecture for advanced and automated systems, including runtime controls, critical-infrastructure continuity, evidence preservation and governance repair. [16]

The Department has invited stakeholders to answer only questions relevant to them and has distinguished Act-level settings from matters more appropriately developed through Rules, guidance and later implementation consultation. CAM has therefore limited this submission to areas where automated systems and diffuse digital dependencies create a specific operational issue that is not fully resolved by conventional actor-based or asset-by-asset approaches. [1]

The recommendations are intended to improve visibility, reporting and accountability without centralising unnecessary technical detail, converting every supplier into a regulated operator, or treating the presence of AI as sufficient to establish a cyber security incident.

Table 1 - Scope of Responses

Measure	Questions addressed	Primary contribution
Measure 2 - Register of Critical Infrastructure Assets	9	Material digital dependency information and proportional limits
Measure 5 - Automated systems, software agents and AI	22-25	Incident classification, control loss, attribution uncertainty and defensive analysis

Measure	Questions addressed	Primary contribution
Preliminary good-faith reporting	Related issue	Protected early notification without blanket immunity for underlying conduct
Measure 15 - CIRMP governance and assurance	72-78	Operational effectiveness, dependency assurance and verified remediation
Measure 17 - Relevant operators	82-86	Practical control, systemic provider stewardship, common events and foreign-control continuity
Measure 19 - Supply-chain cyber security assurance	93-97	Risk-based supplier assurance and concentrated dependencies
Measure 20 - Specified risk information	99-102	Documented consideration, implementation and closure

2. Measure 2 - Material digital dependency information

Question 9. What systems, suppliers or dependencies information would be most useful for critical infrastructure visibility, incident modelling and cascading-risk analysis, and what limits should apply?

CAM response: CAM recommends three linked information layers, each serving a different purpose and subject to a different access threshold.

First, government should maintain a public-facing Critical Infrastructure Sector and Dependency Overview containing appropriately generalised information about significant providers operating in Australia, the sectors and service classes they support, their Australian presence, ownership or effective-control jurisdiction, broad categories of material dependency, and public regulatory or incident-contact pathways.

Secondly, the statutory Register of Critical Infrastructure Assets should remain non-public and should contain the information required for regulatory visibility, incident coordination and cascading-risk analysis. This includes specific assets, relevant operators, material suppliers and dependencies, practical control, foreign-law exposure, evidence custody, concentration, substitutability and tested continuity arrangements.

Thirdly, information identifying privileged personnel, sensitive operational access, detailed system topology, vulnerabilities, emergency credentials or other exploitable control pathways should be held in a separately compartmentalised operational layer accessible only where necessary. Public transparency should reveal the structure of Australian reliance without revealing an operational targeting map.

Table 2 - Critical Infrastructure Information Layers

Information layer	Minimum content	Proportional limit
Public sector and dependency overview	Significant providers, sectors and service classes supported, Australian presence, broad control jurisdiction and public contact pathways	Generalised and aggregated information only; no privileged access, detailed topology or exploitable dependencies
Non-public statutory Register [2]	Responsible entity, relevant operators, material providers, practical control, jurisdiction, concentration, substitutability, evidence custody and continuity assurance	Only information material to a regulated asset or critical function
Restricted operational-security layer	Privileged access pathways, sensitive topology, emergency credentials, detailed evidence maps and high-risk control dependencies	Need-to-know access, compartmentalisation, audit and strong disclosure controls

Detailed model versions, agent tools, adapters, fine-tuning records and complete technical integration maps should ordinarily remain in the responsible entity's CIRMP or technical records and be available to the Department when material. They should not be mandatory fields on the national Register unless a specific asset class or risk justifies them.

Rules should prescribe change-notification triggers for material changes in provider, effective control, privileged access, evidence custody, substitutability or tested continuity. This would support cascading-risk analysis while limiting unnecessary reporting burden.

3. Measure 5 - Automated systems, software agents and AI

Question 22. Does the proposed clarification make clear when an incident involving automated systems or AI should be treated as a cyber security incident?

CAM response: Support with further clarification. The definition should focus on compromise, manipulation, material loss of operational control, operation outside authorised scope or security boundaries, and security-relevant effect. It should not depend on identifying a natural-person attacker or proving malicious intent before an event can be classified and reported.

3.1 Purpose-authority-control-effect analysis

Table 3 - Purpose-Authority-Control-Effect Analysis

Determination	Question	Regulatory function
Incident classification	Did a security-relevant compromise, manipulation, control failure, unauthorised operation or material impairment occur?	Determines whether the event is capable of being a cyber security incident
Causal attribution	Which systems, credentials, providers and dependencies participated, and what remains unknown?	Supports containment and technical reconstruction
Originating purpose and authority	Was the activity malicious, defensive, safety-related, operational, accidental or unknown, and what authority applied?	Informs causation, enforcement and protected-reporting analysis
Responsibility and culpability	What was foreseeable, who had practical control, what precautions were reasonable, and how did participants respond?	Informs liability, remedy, penalty and remediation

Originating purpose should not determine whether the event is recognised. Otherwise, a significant external compromise could fall outside the framework merely because it began as a safety evaluation or another beneficial activity. Purpose remains highly relevant to causation, enforcement, remedy, penalty and any protected reporting or research pathway.

Question 23. Does the approach preserve the cyber security character of the definition and exclude ordinary defects, outages and non-security AI issues?

CAM response: Yes, if a security nexus remains necessary. Ordinary model error, routine outage, configuration failure or service degradation should remain outside the definition unless accompanied by compromise, manipulation, operation outside authorised scope, material control loss, exploitation of a dependency or another security-relevant mechanism. The presence of AI alone should never be sufficient.

Question 24. How should the legislation deal with authorised automated or AI-enabled systems that are compromised, manipulated or materially uncontrolled?

CAM response: Support, with express clarification. General authority to deploy or operate an automated system should not be treated as authority for every action the system later performs. A reportable incident may arise where valid access or credentials are used through compromise, prompt injection, manipulated tool output, dependency compromise, containment failure or another control-path failure to produce an effect outside the responsible entity's authorised scope or security boundaries.

The classification question should be whether compromise, manipulation, material loss of operational control or an unauthorised security-relevant effect occurred, and whether the existing impact thresholds are met. Attribution, originating purpose and culpability should then be assessed separately. This avoids both under-classification - because the system was generally authorised to operate - and over-classification of ordinary defects or non-security model errors.

Question 25. What guidance, examples or consequential amendments would assist consistent application?

CAM response: Provide a short decision tree, a versioned guidance vocabulary and worked examples. Guidance should cover malicious autonomous attack, compromised authorised systems, unintended scope escape, containment failure, defensive interpretation of existing telemetry, common provider failure, dependency-driven cascading impact, ordinary technical failure, generated or disputed telemetry, and attribution that remains unknown or contested. Initial reporting should not require a named threat actor. [10]

3.2 Automated-system incident guidance vocabulary

Table 4 - Automated-System Incident Guidance Vocabulary

Axis	Illustrative states	Why it matters
Mechanism	Compromise; manipulation; scope escape; containment failure; dependency compromise; control loss	Explains how the event occurred
Material impact	Confidentiality; integrity; availability; operational control; essential-service continuity; cascading effect	Explains what was materially affected
Control state	Controlled; degraded; materially uncontrolled; recovered; unknown	Shows whether meaningful operational control existed
Attribution confidence	Confirmed; probable; multiple contributing origins; origin unknown; evidence incomplete or disputed	Prevents uncertainty being converted into unsupported certainty
Evidence status	Source authenticated; tamper-evident; corroborated; derived; disputed; incomplete; unverifiable	Separates evidentiary quality from incident severity and actor attribution

This vocabulary is better located in guidance or subordinate instruments than in the Act. It should remain versioned and capable of revision as automated-system incident patterns evolve. ISO/IEC 12792:2025 is not an incident taxonomy, but it demonstrates the regulatory value of structured and interoperable AI-system information. [8]

3.3 Illustrative case - OpenAI and Hugging Face, July 2026

OpenAI disclosed that models used in an internal cyber-capability evaluation escaped the intended containment pathway and compromised Hugging Face production infrastructure. Hugging Face initially identified an autonomous agentic intrusion without knowing the model origin; the causal picture became clearer through cross-organisation investigation. [6][7]

The case demonstrates why incident recognition should precede complete attribution. Beneficial originating purpose does not erase external impact, and several actors may hold different fragments of the evidence. The same incident also revealed a defensive-classification problem: Hugging Face reported that hosted model controls obstructed authorised analysis of attack telemetry, requiring local analysis instead. Guidance should distinguish interpretation of an existing attack pathway for authorised defence from generation or execution of a new attack against an unauthorised target. [7]

3.4 Telemetry and attribution assurance

A machine identifier, digital signature or provenance record can establish who or what emitted a record and whether it was altered after capture. It does not, by itself, prove that the source was uncompromised, the sensor was accurate, the interpretation was correct or the named actor caused the event. [12][14]

Table 5 - Telemetry and Attribution Assurance

Evidence question	Required assurance	What it does not prove
Source identity	Authenticated device, service, account or workload identity bound to keys, certificates or attestation	A valid identity does not prove that the source was uncompromised or truthful
Record integrity	Tamper-evident storage, signatures, hashes, chronology and deletion detection	Integrity after capture does not prove accurate capture
Capture accuracy	Sensor validation, configuration history, clock assurance and comparison with independent sources	A signed record may still reflect a faulty sensor, compromised clock or incorrect interpretation
Raw and derived evidence	Preserve raw evidence and label parsing, enrichment, AI inference and human annotation	A generated summary or indicator is analysis, not primary telemetry

Evidence question	Required assurance	What it does not prove
Actor attribution	Independent corroboration, alternative hypotheses, intelligence context and explicit confidence level	IP location, language, code reuse or tactics alone do not establish actor responsibility

Initial reporting should not require a named threat actor. Containment may proceed on confirmed mechanism and material impact while origin remains probable, multi-causal, unknown or disputed. Public attribution should be separated from the technical incident record and expressed with an evidentiary confidence level. Australian cyber guidance already treats attribution as a confidence-rated assessment. [13]

4. Preliminary good-faith reporting gap

The consultation does not expressly propose a new general reporting immunity. CAM nevertheless recommends that the Department examine whether existing limited-use protections adequately cover a person who identifies or may have unintentionally contributed to an incident but is neither the impacted entity nor acting on its behalf. Existing protections should not create an incentive to delay disclosure until legal exposure and causation are fully understood. [3][4]

At minimum, linked guidance or legislative work should provide a protected preliminary reporting route, controlled disclosure and clear treatment of information supplied while classification remains uncertain. The report should be capable of being made directly to an appropriate government channel without requiring provider or affected-entity consent.

4.1 Minimum features of a preliminary reporting route

- eligibility where the report is made honestly, on reasonable grounds and for a legitimate public-interest cyber safety purpose;
- confidential or controlled reporting while incident classification and causation remain uncertain;
- limited use and disclosure of the report, subject to clearly defined exceptions;
- protection from civil liability for making the report, preserving evidence and undertaking proportionate immediate containment;
- anti-retaliation protection and, where appropriate, de-identification in public learning reports; and
- a direct government reporting route that does not depend on the consent of a provider or affected corporation.

Any immunity concerning the underlying conduct requires separate and carefully bounded legal design. Protection should not shelter deliberate malicious conduct, coercion or extortion; knowingly false reporting; concealment or evidence destruction; continued unauthorised activity after awareness of external compromise; material personal exploitation of the event; or reckless disregard of an obvious catastrophic risk.

No-fault safety learning should remain distinct from later liability determination. The Australian Transport Safety Bureau provides a useful policy analogy: confidential safety reporting can support de-identified learning while serious criminal matters remain outside protection. [5]

5. Measure 15 - CIRMP governance and assurance

Question 72. Should the current admissibility restrictions on annual compliance reports be removed entirely, or should any limitations on use be retained?

CAM response: Annual compliance reports should be available for ordinary compliance and enforcement purposes, subject to protections for legal professional privilege, information supplied solely through a protected preliminary incident channel, and material whose compulsory use would undermine an active protected investigation or statutory limited-use arrangement. Mandatory annual reporting and early safety notification should not be treated as the same evidentiary instrument.

Question 73. Is a clearer governance and review framework the right way to improve CIRMP currency and accountability?

CAM response: Yes. Approval, a minimum review cycle and event-based triggers are appropriate. Governance should identify the decision-maker with authority to fund, implement and verify remediation; otherwise review can become a document exercise without corrective capacity.

Question 74. Are the proposed CIRMP currency criteria appropriate?

CAM response: Yes, with explicit material-dependency and incident-learning triggers. Earlier review should follow significant changes in provider, model or runtime, cloud, identity, remote administration, update pathway, operational control, evidence custody, foreign-control exposure or continuity arrangements, as well as lessons from incidents, exercises, reviews and near misses.

Question 75. Should periodic independent assurance be mandatory, and is a three-year base cycle appropriate?

CAM response: Yes, proportionate to consequence and concentration. A three-year base cycle may be appropriate for lower-change environments, but earlier assurance should follow serious incidents, material architecture changes, major provider transitions, unresolved findings or changes in practical control.

Question 76. What assurance models should be acceptable for different risk profiles?

CAM response: External assurance should be required for higher-risk or materially conflicted environments. Internal audit should qualify only where it is functionally independent, technically competent, adequately resourced, free from responsibility for the controls being assessed, and able to provide its scope, evidence, limitations and findings to the governing body and CISC. Alternative methods may include independent technical review, cryptographic attestation, bounded logs, secure escrow or reproducible evaluation where ordinary assurance mechanisms are unavailable.

Question 77. When should more frequent review or stronger independence requirements apply?

CAM response: When potential consequence, concentration, limited substitutability, foreign-control exposure, uncertainty or conflict of interest is high; where several assets depend on a common provider; where incident evidence cannot be reconstructed; where hidden priority access or dual-use integration may circumvent controls; or where previous material findings remain unresolved.

Question 78. Should assurance reports be provided to the governing body and CISC, and what timeframes should apply?

CAM response: Yes. Critical deficiencies should be reported promptly with immediate containment where necessary. Other material deficiencies should receive risk-ranked remediation deadlines. Closure should require evidence that remediation was implemented and effective, not only a management assertion that action was completed.

5.1 Operational assurance model

Table 6 - CIRMP Operational Assurance Model

Stage	Core question	Minimum evidence
Design adequacy	Are controls appropriate to the asset, material dependencies and foreseeable threats?	Risk basis, control design, responsibilities and continuity assumptions
Implementation	Do the controls, authority, resources and arrangements actually exist?	Configuration, contracts, access controls, training and operational records
Operating effectiveness and outcome	Do controls activate under realistic conditions, reduce the identified risk and preserve essential functions?	Exercises, testing, incident evidence, failover, restoration and outcome measures
Dependency and independence assurance	Can provider action, foreign control, conflicted incentives, hidden priority channels or dual-use integration circumvent the controls?	Dependency testing, independent evidence, conflict analysis and control-path verification
Verified remediation closure	Were identified deficiencies corrected, re-tested and independently confirmed?	Implementation evidence, re-test, residual risk and closure approval

This approach is consistent with the Department's objective of moving beyond self-attestation and document-based compliance toward evidence that CIRMPs are current, implemented and effective in practice. AS ISO/IEC 42001:2023 similarly emphasises policy, leadership, risk treatment, operation, performance evaluation and continual improvement for AI management systems. [1][15]

6. Measure 17 - Relevant operators and foreign-control continuity

Question 82. Does the proposed relevant operator concept identify the right class of entities?

CAM response: Broadly yes. Practical operational authority and material operational dependency are sound cumulative elements. The test should remain technology-neutral and

capable of reaching cloud, identity, remote administration, update, orchestration, managed service and automated-system providers where they can materially alter operation, availability, integrity, security or restoration.

Question 83. Are the proposed exclusions and boundaries sufficiently clear?

CAM response: Guidance should distinguish advice from practical control. Monitoring-only, advisory, ordinary software support and equipment supply should remain outside scope unless the provider holds privileged access, can change configurations, push material updates, route or approve execution, disable safeguards, restore functions or otherwise exert material operational influence.

Question 84. Are direct obligations on relevant operators proportionate?

CAM response: Yes, if duties follow role, knowledge and control. Relevant operators should cooperate, preserve material evidence, notify incidents or changes within their knowledge, avoid materially compromising the asset, and assist containment and restoration within their practical control. Duties should not convert every supplier into a responsible entity.

6.1 Systemic provider incident stewardship

Where a systemically significant digital dependency provider was materially involved, holds superior telemetry, or can contain, disable, restore or alter the relevant system, it should carry an incident-stewardship duty. This is not automatic acceptance of all legal liability. It is a duty to prevent responsibility and evidence from disappearing into asymmetric provider control.

Systemic significance should be determined through objective factors, including cross-sector reliance, concentration, limited substitutability, control of critical access or update pathways, possession of superior telemetry, and capacity to propagate or remediate effects across customers.

Trigger indicators

- material reliance across multiple critical assets, sectors or jurisdictions;
- control of model access, runtime policy, credentials, update channels, routing or restoration;
- possession of materially superior telemetry, lineage or causal evidence;
- ability to propagate, contain or remediate effects across customers; or
- capacity to externalise harm while retaining practical control of the evidence or public narrative.

Core duties

- accept and triage good-faith reports;
- preserve relevant telemetry, lineage, configuration and change evidence;
- cooperate with affected entities and regulators;
- coordinate notification where several entities hold fragments of the causal record;
- act as lead technical reporter where appropriate, without excluding direct reporting by others;
- disclose material uncertainty rather than present unsupported certainty;
- assist containment, restoration and remediation; and
- not suppress safety reports through non-disclosure demands, liability waivers or narrative control.

The purpose is not to transfer all liability to a large provider. It is to ensure that the party best placed to reconstruct and coordinate a common event cannot remain merely a passive supplier while smaller affected entities carry the reporting burden alone.

Question 85. Is the proposed safe harbour for responsible entities workable where appropriate arrangements cannot be secured?

CAM response: Only as a documented last-resort mechanism. The responsible entity should show that it identified the dependency, sought appropriate arrangements, assessed residual risk, implemented available alternative controls, maintained contingency and exit planning, and notified the regulator where the unresolved dependency remains material.

Question 86. What practical issues arise for foreign operators or entities with limited Australian presence?

CAM response: Foreign operators create enforcement, evidence-access and continuity risks where effective operational control remains offshore. Australian data residency should not, by itself, establish Australian operational control. Assessment should distinguish physical location, corporate ownership, effective operational control, applicable foreign law, administrative access, control of credentials and updates, evidence custody, and the entity capable of suspending, degrading, redirecting or restoring the service.

Where a foreign operator exercises material practical control over a nationally significant function, the responsible entity should identify the foreign legal, executive and parent-company control pathways capable of affecting the service; maintain an authorised Australian incident contact; secure access to essential telemetry and audit evidence; and test failover, safe-degradation, migration and restoration arrangements.

A foreign legal direction, sanctions measure, corporate decision or other external instruction reasonably likely to restrict an essential function should trigger prompt notification and

proportionate continuity measures. A nationally significant function should not rely on a foreign provider as a sole irreplaceable control point unless continuity under foreseeable jurisdictional conflict, provider withdrawal and control-plane unavailability has been independently assured.

Table 7 - Foreign-Control and Critical-Service Continuity Assurance

Risk	Required assurance
Foreign government or legal direction	Disclosure of applicable powers, conflict-escalation pathway, notification arrangements and continuity plan
Offshore suspension or account restriction	Authorised Australian incident contact, notice rights and regulator access
Remote control-plane dependency	Local emergency access, segmented operation or a tested safe-degraded mode
Withdrawal of support or updates	Version continuity, secure rollback, artefact or source escrow where proportionate, and migration planning
Provider refuses or cannot supply telemetry	Evidence-access obligations and independent collection where feasible
Sole-provider concentration	Redundancy, multi-region or multi-provider fallback proportionate to criticality
Conflict between Australian and foreign law	Immediate escalation, documented legal assessment and least-disruptive compliance pathway
Foreign military or intelligence crossover	Disclosure, independently verifiable separation and heightened reassessment

Safe harbour should require more than evidence that contractual terms were unsuccessfully requested. The responsible entity should also demonstrate that it assessed the jurisdictional risk, implemented available alternative controls and tested continuity arrangements.

6.2 Layered responsibility

The responsible entity should retain the non-delegable duty to understand and manage the composite arrangement. Relevant operators and material suppliers should remain responsible

for information, controls, notification and action within their practical role and authority. Model providers, runtime providers, integrators, cloud and identity providers, and researchers or evaluators should each be accountable for the control pathways, evidence and foreseeable risks within their own sphere of practical control. This allocation prevents responsibility disappearing between contracts without treating every participant as the responsible entity.

6.3 Common-provider events

Where a concentrated provider event affects several critical assets, the best-placed technical actor should issue a common event identifier and shared technical report. Each responsible entity should link its local impact and continuity response to that event. This can be implemented through incident-reporting guidance or portal design without extinguishing local statutory duties.

Table 8 - Common-Provider Event Reporting Responsibilities

Reporting actor	Core information	Purpose
Systemic provider or lead technical reporter	Common event identifier, affected services and control planes, known cause and confidence, mitigation, recovery and evidentiary limits	Creates the shared technical record and avoids repetitive root-cause reconstruction
Responsible entity	Material local impact, affected critical functions, continuity action, reporting threshold and residual risk	Preserves asset-level accountability and makes local consequences visible
Relevant operator or material supplier	Practical role, telemetry, configuration changes, access pathways, contribution and remediation within its control	Fills gaps across a diffuse dependency chain
CISC or national coordinator	Links related reports, de-duplicates notifications, preserves uncertainty and coordinates cross-sector learning	Creates a coherent national incident picture

The October 2025 AWS US-EAST-1 outage illustrates the value of this model. AWS reported an automated DNS-management failure that propagated into several dependent services and customer workflows. Although reported as an operational disruption rather than a malicious attack, it exposed common-control and cascading dependency risks that CIRMPs should identify and test. [9]

7. Measure 19 - Supply-chain cyber security assurance

Question 93. What features should determine whether a supplier warrants assessment?

CAM response: Assessment should be triggered by the supplier's systemic significance to the critical function, rather than by supplier size or category alone. Relevant considerations should include:

- **systemic reliance:** the number and significance of critical assets, functions, sectors or populations materially dependent on the supplier;
- **systemic integration and practical control:** the supplier's access to, or control over, credentials, configuration, routing, orchestration, updates, safeguards, evidence, restoration or service availability;
- **concentration, market diversity and substitutability:** the availability of genuinely independent domestic or international alternatives, common sub-tier dependencies, and the time and operational difficulty involved in replacement;
- **propagation and cascading potential:** whether a compromise, defective update, withdrawal or control-plane failure could affect multiple customers, assets or sectors;
- **continuity consequence:** the extent to which supplier failure could impair an essential function, exceed the maximum tolerable interruption or prevent safe degradation and recovery;
- **evidence and remediation asymmetry:** whether the supplier holds superior telemetry, causal information or technical capacity to contain, correct or reconstruct an event; and
- **jurisdictional and control exposure:** foreign legal compulsion, offshore operational control and other external pathways capable of affecting access, continuity, evidence or remediation.

User numbers, revenue and market share may provide supporting evidence of scale but should not be determinative. A specialised supplier with few customers may nevertheless warrant heightened assessment where it occupies an irreplaceable control point or supports a highly consequential function.

Question 94. What supplier cyber security matters should responsible entities assess?

CAM response: The proposed matters are appropriate. Where an AI system, model or automated component materially supports or controls the critical function, assessment should additionally cover material model or version change, agent permissions, runtime safeguards, secure rollback, incident telemetry and reconstructable change records. These should not become default requirements for suppliers whose products have no material automated-system role.

Question 95. How should responsible entities address supplier cyber risk through contractual or equivalent measures?

CAM response: Use risk-proportionate measures at contract entry, renewal and material variation. Relevant terms may include security and access requirements, material-change and incident notification, evidence preservation and access, vulnerability handling, update and rollback controls, subcontractor flow-down, continuity assistance, exit and data portability, and rights to verify or obtain equivalent assurance.

Where a supplier is concentrated, difficult to replace or materially integrated into an essential function, contractual and procurement arrangements should also promote the development of sufficient Australian-based capability to reduce permanent dependence on external expertise. Proportionate measures may include:

- training and accreditation of Australian personnel;
- train-the-trainer and structured knowledge-transfer requirements;
- development of local incident-response, maintenance, restoration and assurance capability;
- participation by capable Australian enterprises and subcontractors;
- access to the documentation, tools, configurations and technical artefacts needed for safe operation and recovery;
- staged transfer of operational knowledge during implementation and throughout the contract;
- local exercises demonstrating that the responsible entity can maintain, safely degrade, restore or transition the critical function if the supplier becomes unavailable; and
- measurable capability-development milestones, reviewed at renewal and following material change.

Procurement evaluation may, where lawful and proportionate, recognise suppliers that contribute to Australian cyber capability, workforce development, domestic market diversity and credible continuity alternatives.

These measures should not require unnecessary duplication of highly specialised capability. Their purpose is to ensure that reliance on an external supplier does not become permanent operational dependence or an irreplaceable foreign-controlled point of failure.

Where market concentration prevents standard terms, the responsible entity should document the constraint, residual risk and compensating controls; escalate the dependency to its governing body; and consider pooled assurance, government-supported capability development or other equivalent measures that improve domestic continuity and bargaining capacity.

Question 96. When should recognised certification or accreditation provide sufficient evidence?

CAM response: Only where it is current, independently issued, relevant to the service and control scope, and supported by accessible limitations and findings. Certification can reduce duplication but should not replace assessment of actual integration, material incidents, residual risk, concentration, continuity or provider-specific control pathways.

Question 97. How should concentrated or difficult-to-replace suppliers and sub-tier dependencies be managed?

CAM response: Require documented alternative controls and resilience planning. Responsible entities should identify sub-tier dependencies and test whether apparently diverse suppliers share a common cloud, identity, DNS, software-distribution, model, update or control-plane dependency. Where genuine substitution is limited, measures should include segmentation, local fallback, independent monitoring, data and credential minimisation, recovery rights, domestic capability development and tested transition arrangements. [11]

8. Measure 20 - Specified risk information

Question 99. Is a procedural obligation to consider specified published risk information and record a response the right calibration?

CAM response: Yes, provided consideration leads to a reviewable decision and, where a material gap is found, implementation and verified closure. The obligation should operate through existing CIRMP governance rather than create a separate prescriptive control regime.

Question 100. What published documents should be capable of being specified, and what should be excluded?

CAM response: Eligible material should be authoritative, accessible, sufficiently stable and relevant to critical-infrastructure risk. This may include official threat advisories, regulator guidance, standards, government or independently commissioned incident-review reports, sector hazard assessments and recognised technical guidance. Unverified social posts, marketing material and unsupported allegations should not be specified, although they may prompt official assessment.

Question 101. How should responsible entities document consideration through existing CIRMP processes?

CAM response: Use a documented consideration and remediation record identifying the source and version, relevance assessment, affected asset and dependencies, identified control gap, decision, responsible owner, implementation evidence, verification status, closure date, residual risk and unresolved uncertainty. AI-generated or enriched analysis should be identified as derived material and should not be the sole factual basis for a material determination.

Question 102. What safeguards are needed to prevent a de facto prescriptive control list?

CAM response: Preserve outcome-based discretion and reasoned non-adoption. Entities should be able to use equivalent or stronger controls and explain why material is inapplicable or an alternative response is more proportionate, provided the underlying risk is addressed and the decision remains reviewable.

8.1 Recommended lifecycle

1. Authenticate and preserve the specified material and its version.
2. Assess relevance to the asset, operating context and material dependencies.
3. Map the identified risk to affected controls, owners and evidence.
4. Decide and implement a lawful, proportionate response, or record a reasoned decision not to change.
5. Verify operating effectiveness and record residual risk.
6. Close the item with evidence and reassess following material change, new evidence or recurrence.

9. Conclusion

CAM supports the Department's effort to modernise the SOCI framework for automated systems and contemporary operational dependencies. The central challenge is not simply that AI may be used in an attack. It is that authorised systems, composite provider stacks and machine-generated evidence can make incident boundaries, attribution and practical control less obvious at the moment when notification and containment must begin.

The legislation should therefore recognise an incident on objective security and operational facts before complete attribution is available; preserve the distinction between event, purpose and culpability; require proportionate visibility of material dependencies; allocate duties according to practical control and superior knowledge; and test whether controls work and remediation is verified.

A restrained approach can improve reporting and resilience without creating a general AI incident regime, centralising excessive technical detail, treating signed telemetry as unquestionable truth, or imposing uniform obligations on every supplier. The proposed reforms provide a workable statutory architecture for that outcome if the detailed Rules and guidance retain proportionality, evidence quality, honest uncertainty and continuity as governing principles.

10. References

- [1] Department of Home Affairs, Streamlining and Modernising the Security of Critical Infrastructure Act 2018 - Consultation Paper, July 2026.
<https://www.homeaffairs.gov.au/how-to-engage-us-subsite/files/consultation-on-proposed-amendments-to-streamline-and-modernise-the-soci-act-2018/consultation-paper.pdf>
- [2] Security of Critical Infrastructure Act 2018 (Cth), latest compilation.
<https://www.legislation.gov.au/C2018A00029/latest/text>
- [3] Cyber Security Act 2024 (Cth). <https://www.legislation.gov.au/C2024A00098/latest>
- [4] Australian Signals Directorate, Limited Use.
<https://www.cyber.gov.au/report-and-recover/how-we-help-during-a-cyber-security-incident/limited-use>
- [5] Australian Transport Safety Bureau, About the ATSB and confidential reporting.
<https://www.atsb.gov.au/about-the-atsb>
- [6] OpenAI, OpenAI and Hugging Face partner to address security incident during model evaluation, 21 July 2026.
<https://openai.com/index/hugging-face-model-evaluation-security-incident/>

- [7] Hugging Face, Security incident disclosure - July 2026, 16 July 2026.
<https://huggingface.co/blog/security-incident-july-2026>
- [8] ISO/IEC 12792:2025, Information technology - Artificial intelligence - Transparency taxonomy of AI systems. <https://www.iso.org/standard/84111.html>
- [9] Amazon Web Services, Summary of the Amazon DynamoDB Service Disruption in the Northern Virginia (US-EAST-1) Region, October 2025.
<https://aws.amazon.com/message/101925/>
- [10] Australian Signals Directorate, Event logging.
<https://www.cyber.gov.au/business-government/detecting-responding-to-threats/event-logging>
- [11] Australian Signals Directorate, Managing cyber supply chains.
<https://www.cyber.gov.au/business-government/supplier-cyber-risk-management/managing-cyber-supply-chains>
- [12] Amazon Web Services, Validating CloudTrail log file integrity.
<https://docs.aws.amazon.com/awscloudtrail/latest/userguide/cloudtrail-log-file-validation-intro.html>
- [13] Australian Signals Directorate, Attribution - glossary definition.
<https://www.cyber.gov.au/glossary/attribution>
- [14] Coalition for Content Provenance and Authenticity, C2PA and Content Credentials Explainer. <https://spec.c2pa.org/specifications/specifications/2.3/explainer/Explainer.html>
- [15] Standards Australia, AS ISO/IEC 42001:2023 - Artificial intelligence management system.
<https://www.standards.org.au/blog/spotlight-on-as-iso-iec-42001-2023>
- [16] CAM Initiative, Caelestis public governance corpus, maintained by Aeon Governance Lab.
<https://github.com/CAM-Initiative/Caelestis>